Rapporto di valutazione delle vulnerabilità

13 ottobre 2026

Descrizione del sistema

L'hardware del server comprende un processore potente e 128 GB di memoria. Funziona con l'ultima versione del sistema operativo Linux e ospita un sistema di gestione di database MySQL. È configurato con una connessione di rete stabile che usa indirizzi IPv4 e comunica con altri server della rete. Le misure di sicurezza includono connessioni cifrate SSL/TLS.

Ambito

L'ambito di questa valutazione delle vulnerabilità riguarda i controlli di accesso attuali del sistema. La valutazione coprirà un periodo di tre mesi, da giugno 20XX ad agosto 20XX. Per guidare l'analisi del rischio del sistema informativo si usa NIST SP 800-30 Rev. 1.

Scopo

Il server di database archivia e gestisce i dati dei clienti, delle campagne e delle analisi che il team marketing usa per seguire i risultati e personalizzare il proprio lavoro. È in uso ogni giorno, quindi l'azienda ne dipende.

- *Proteggere quei dati è importante perché in questo momento i permessi sul sistema sono molto aperti. Una fuga di dati o una modifica fatta dalla persona sbagliata danneggerebbe i clienti, potrebbe portare sanzioni e rovinerebbe la reputazione dell'azienda.*
- *Se il server fosse fuori uso, le attività di marketing si fermerebbero finché non torna online, e il team perderebbe tempo e denaro.*
- *Quale impatto avrebbe il server sull'azienda se fosse fuori uso?*

Valutazione del rischio

Fonte della minaccia	Evento di minaccia	Probabilità	Gravità	Rischio
Hacker	Ottiene informazioni sensibili tramite esfiltrazione, aiutato dai permessi di accesso troppo aperti	3	3	9

Dipendente	Blocca operazioni fondamentali, oppure copia dati usando più accesso del necessario	2	3	6
Cliente	Modifica o cancella informazioni critiche	1	3	3
Hacker	Legge i dati in transito perché la connessione usa il vecchio SSL	2	2	4

Approccio

I rischi hanno tenuto conto dei metodi con cui l'azienda archivia e gestisce i dati. La probabilità che si verifichi una minaccia e l'impatto di questi eventi potenziali sono stati valutati rispetto ai rischi per le esigenze operative di ogni giorno.

Strategia di correzione

Introdurre meccanismi di autenticazione, autorizzazione e audit, per assicurare che solo gli utenti autorizzati accedano al server di database. Questo comprende password forti, controlli di accesso basati sul ruolo e autenticazione a più fattori per limitare i privilegi degli utenti. Cifratura dei dati in transito con TLS al posto di SSL. Lista di indirizzi IP consentiti limitata agli uffici dell'azienda, per evitare che utenti casuali da internet si colleghino al database.